

Vulnerability Assessment Report

Maximilian Rivera | Security Portfolio | June 2026

SYSTEM DESCRIPTION

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures currently include SSL/TLS encrypted connections.

SCOPE

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment covers a period of three months, from June 20XX to August 20XX. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

PURPOSE

The database server is the backbone of how the company finds and pursues new customers. Without it, business development stops. The problem is that this server has been publicly accessible for three years with no authentication layer blocking outside access, meaning anyone with an internet connection can query it. This assessment was conducted to put real numbers behind that risk, identify the most likely attack scenarios given the current configuration, and give decision makers the information they need to act before this becomes an incident.

RISK ASSESSMENT

Threat Source	Threat Event	Likelihood	Severity	Risk
Outsider (Hacker / APT)	Obtain sensitive information via exfiltration	3	3	9
Competitor	Conduct Denial of Service (DoS) attacks	2	3	6
Outsider (Unauthorized user)	Alter/Delete critical information	2	2	4

Risk Score Key: 9 = Critical | 6 = High | 4 = Moderate | 1-3 = Low (Likelihood x Severity)

APPROACH

I focused on three threat sources that are directly enabled by an open, unauthenticated server: external attackers looking to steal data, competitors motivated to disrupt operations, and unauthorized users who could modify or wipe records. These are not edge cases. They are the most predictable outcomes of leaving a database exposed to the public internet for three years with no access controls in place. Likelihood scores reflect the low barrier to entry the current configuration creates. Severity scores reflect the direct impact each scenario would have on the company's ability to operate and retain customer trust. All scoring was done using NIST SP 800-30 Rev. 1 as the reference framework.

REMEDIATION STRATEGY

The fix starts with access control. No one should be able to query this database without authenticating first, and once they're in, they should only see what their role requires. That means enforcing multi-factor authentication for all employee accounts and applying the principle of least privilege across the board. On the network side, rate limiting and perimeter filtering would reduce the DoS exposure without impacting day-to-day operations. Beyond that, every database session needs to be logged. Right now there is no visibility into who is accessing what or when. Logging and monitoring gives the team the ability to catch suspicious activity, like bulk data exports or off-hours queries, before it becomes a breach.